



Politécnico
Internacional

ASEGURAMIENTO DE INFRAESTRUCTURA DE REDES Y SISTEMAS

"La seguridad es un proceso, no un producto."

– *Bruce Schneier*, experto en criptografía y seguridad informática.

- ☐ ¿Que es una política de seguridad de la informacion?
- ☐ ¿Como aplicar la política de seguridad de la informacion?
- ☐ Fases para aplicar la política de seguridad de la informacion.
- ☐ Cual es el propósito principal de seguridad de la informacion
- ☐ ¿Que es una política de acceso basada en roles RBAC?
- ☐ Rol CISO
- ☐ ISO 27001
- ☐ Conclusiones

Política de Seguridad de la Información

Es un conjunto formal de directrices y normas establecidas por una organización para proteger sus activos de información. Define los principios, responsabilidades, comportamientos aceptables, controles y procedimientos que deben seguir empleados, proveedores y usuarios para garantizar la confidencialidad, integridad y disponibilidad de la información. Elementos clave:

- Gestión de accesos
- **Clasificación de la información**
- Uso aceptable de recursos
- Respuesta ante incidentes
- **Seguridad física y lógica**

Ejemplo:

Una universidad define en su política que solo los administradores del sistema pueden acceder a los servidores que almacenan las calificaciones de los estudiantes. Además, establece que todos los usuarios deben cambiar sus contraseñas cada 90 días y que está prohibido compartir credenciales por correo electrónico.



¿Cómo aplicar la política de seguridad de la información?

La implementación de la política se realiza mediante la integración de controles administrativos, técnicos y físicos, acompañada de procesos de concienciación, monitoreo y mejora continua. Se deben definir roles, asignar responsabilidades y asegurar el cumplimiento a través de auditorías y sanciones. **Pasos clave para aplicarla:**

- **Difusión y capacitación:** Capacitar a todo el personal sobre las políticas y consecuencias de su incumplimiento.
- **Configuración de controles técnicos:** Implementar firewalls, control de accesos, cifrado y autenticación multifactor.



¿Cómo aplicar la política de seguridad de la información?

- **Supervisión y auditoría:** Monitorear el cumplimiento mediante logs, SIEM y revisiones periódicas.
- **Gestión de incidentes:** Establecer canales de reporte y respuesta rápida ante eventos de seguridad.
- **Actualización periódica:** Revisar la política al menos una vez al año o tras incidentes relevantes.

Ejemplo:

En una entidad financiera, se aplica la política obligando al uso de VPN cifrada para acceder al sistema bancario desde fuera de la red corporativa. Además, se configuran roles para que solo el área de tesorería pueda transferir fondos, y se ejecutan auditorías mensuales para verificar accesos indebidos.



Fases para aplicar la política de seguridad de la información

1. Diagnóstico y evaluación inicial

Se identifica el estado actual de la seguridad en la organización: activos de información, riesgos existentes, amenazas y vulnerabilidades.

🔧 **Ejemplo:** Escaneo de red con **Nmap** para identificar puertos y servicios expuestos.

2. Diseño de la política

Se redactan los lineamientos, normas, roles y procedimientos de seguridad alineados con estándares (como ISO/IEC 27001).

■ **Incluye:** control de accesos, clasificación de la información, uso aceptable de TI, etc.

3. Aprobación y comunicación

La alta dirección aprueba formalmente la política. Se comunica a todos los usuarios mediante capacitaciones, correos internos, manuales y reuniones.

🔊 **Ejemplo:** Módulo virtual obligatorio sobre ciberseguridad para todo el personal.



Fases para aplicar la política de seguridad de la información

4. Implementación de controles

Se aplican las medidas técnicas, administrativas y físicas.

Ejemplo: Activar autenticación multifactor (2FA), cifrado de discos duros, políticas de contraseñas, instalación de antivirus corporativo.

5. Monitoreo y seguimiento

Se revisa el cumplimiento de la política mediante herramientas de monitoreo, SIEM, auditorías y análisis de logs.

Ejemplo: Uso de Graylog o Splunk para analizar accesos indebidos.

6. Mejora continua

Se ajusta la política con base en nuevas amenazas, resultados de auditorías, incidentes y cambios en la infraestructura.

Ejemplo: Actualización de políticas tras detectar intentos de phishing en correos institucionales.



Propósito Principal de la política de seguridad de la información

Establecer el marco normativo y estratégico que permite proteger los activos de información de una organización frente a amenazas internas y externas, garantizando la confidencialidad, integridad y disponibilidad de los datos.

Objetivos clave:

- Prevenir accesos no autorizados
- Minimizar riesgos de pérdida o alteración de la información
- Garantizar la continuidad del negocio
- Cumplir con normativas legales y estándares internacionales (ISO/IEC 27001, GDPR, etc.)



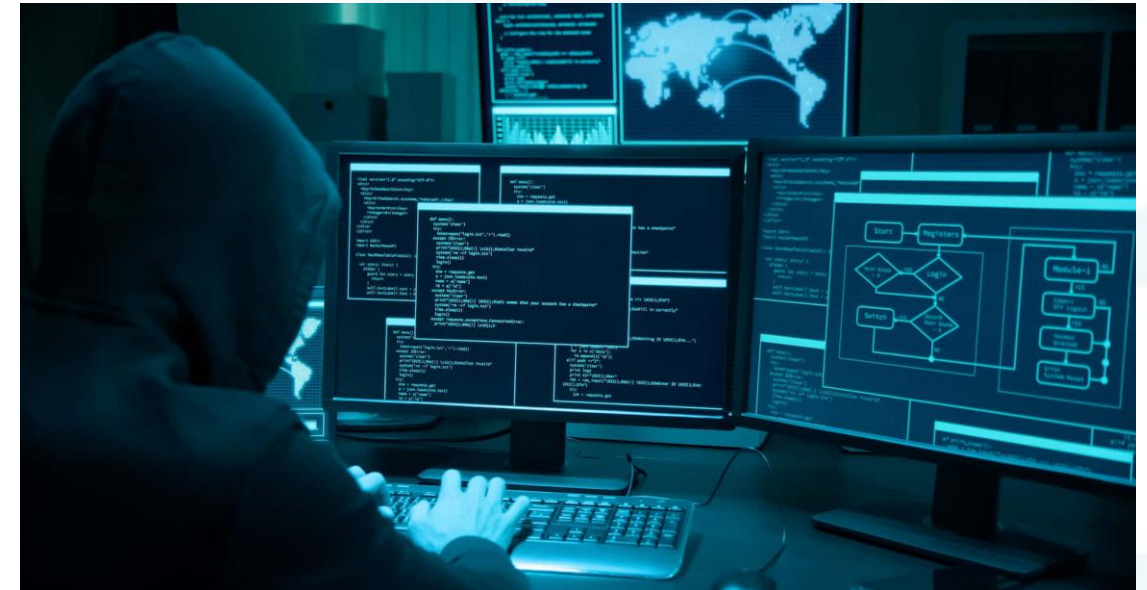
Rol CISO

El **CISO** es el responsable máximo de la seguridad de la información dentro de una organización. Su función es desarrollar, implementar y supervisar estrategias y políticas que protejan los activos digitales frente a amenazas, cumpliendo con normas internas y externas. Responsabilidades clave:

- Diseñar y mantener la Política de Seguridad de la Información.
- Gestionar riesgos tecnológicos y cibernéticos.
- Supervisar planes de respuesta a incidentes.
- Velar por el cumplimiento de normativas (ISO/IEC 27001, NIST, GDPR, etc.).
- Coordinar equipos de seguridad TI, análisis forense y auditoría.
- Reportar al nivel ejecutivo (CIO o CEO).

Ejemplo:

En una entidad financiera, el **CISO** lidera la implementación de un SIEM (Security Information and Event Management) para monitorear en tiempo real los intentos de acceso no autorizado a la banca en línea, y activa el protocolo de respuesta ante incidentes si detecta un ataque DDoS.



ISO/IEC 27001

ISO/IEC 27001 es un estándar internacional que especifica los requisitos para establecer, implementar, mantener y mejorar un **Sistema de Gestión de Seguridad de la Información (SGSI)**. Su objetivo es proteger de manera sistemática la confidencialidad, integridad y disponibilidad de la información. Ejes principales:

Evaluación y tratamiento de riesgos

Política de seguridad de la información

Controles y objetivos de control (Anexo A con 93 controles organizados en 4 temas)

Mejora continua (Ciclo PHVA: Planear – Hacer – Verificar – Actuar)

Ejemplo:

Una empresa de salud implementa ISO 27001 para proteger las historias clínicas de sus pacientes. Establece controles como cifrado de datos, autenticación multifactor, y realiza auditorías internas periódicas para asegurar el cumplimiento de la norma.



CONCLUSIONES